

Ethical Hacking Lab Report

Name Djemtchimo Noukui Bruno Jonatan
Matricule ICTU20241585
Course Ethical Hacking
Lecturer Dr. Nkandeu Pascal
Exercises 1 to 4

Exercise 1: Passive Reconnaissance & Network Discovery

Summary

Reconnaissance on the lab network (192.168.56.0/24): found live hosts and open ports with arp-scan and Nmap. Confirmed the scan traffic in Wireshark. No exploitation at this stage.

Lab Setup

Two machines, same isolated host-only network, no internet access.

Machine	IP Address	Role
Kali Linux	192.168.56.102	Attacker machine (Nmap, arp-scan, Wireshark)
Metasploitable 2	192.168.56.101	Target (vsftpd, Samba, Apache, MySQL, etc.)

1. Steps and Results

1.1 ARP Scan

Find devices on the local network.

```
sudo arp-scan --local
sudo arp-scan 192.168.56.0/24
```

Both commands found the same three hosts.

IP	MAC
192.168.56.1	0a:00:27:00:00:1d (gateway)
192.168.56.100	08:00:27:dc:2b:e5
192.168.56.101	08:00:27:44:30:bc

The “Cannot open MAC/Vendor file” warnings are just permission errors when reading arp-scan’s vendor database. They have no effect on results.

```
bruno@kali: ~  
Session Actions Edit View Help  
zsh: corrupt history file /home/bruno/.zsh_history  
(bruno@kali)-[~]  
$ sudo arp-scan --local  
[sudo] password for bruno:  
Interface: eth0, type: EN10MB, MAC: 08:00:27:b3:b7:93, IPv4: 192.168.56.102  
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied  
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied  
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)  
192.168.56.1 0a:00:27:00:00:1d (Unknown: locally administered)  
192.168.56.100 08:00:27:dc:2b:e5 (Unknown)  
192.168.56.101 08:00:27:44:30:bc (Unknown)  
  
3 packets received by filter, 0 packets dropped by kernel  
Ending arp-scan 1.10.0: 256 hosts scanned in 2.001 seconds (127.94 hosts/sec). 3 responded  
(bruno@kali)-[~]  
$
```

Figure 1: arp-scan -local

Output: Lists the three local hosts (gateway, .100, target .101) by MAC. This confirms Layer 2 reachability.

```
(bruno@kali)-[~]  
$ sudo arp-scan 192.168.56.0/24  
Interface: eth0, type: EN10MB, MAC: 08:00:27:b3:b7:93, IPv4: 192.168.56.102  
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied  
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied  
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)  
192.168.56.1 0a:00:27:00:00:1d (Unknown: locally administered)  
192.168.56.100 08:00:27:dc:2b:e5 (Unknown)  
192.168.56.101 08:00:27:44:30:bc (Unknown)  
  
3 packets received by filter, 0 packets dropped by kernel  
Ending arp-scan 1.10.0: 256 hosts scanned in 1.867 seconds (137.12 hosts/sec). 3 responded  
(bruno@kali)-[~]  
$
```

Figure 2: arp-scan on the full subnet – same result

Output: Scanning the full /24 returns the same three hosts, confirming the subnet boundary.

1.2 Ping Sweep

Nmap's `-sn` sweeps the subnet without scanning ports.

```
nmap -sn 192.168.56.0/24
```

```
(bruno@kali)-[~]  
$ nmap -sn 192.168.56.0/24  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-13 07:50 EDT  
Stats: 0:00:02 elapsed; 0 hosts completed (0 up), 255 undergoing ARP Ping Scan  
Parallel DNS resolution of 3 hosts. Timing: About 0.00% done  
Nmap scan report for 192.168.56.1  
Host is up (0.00080s latency).  
MAC Address: 0A:00:27:00:00:1D (Unknown)  
Nmap scan report for 192.168.56.100  
Host is up (0.00044s latency).  
MAC Address: 08:00:27:DC:2B:E5 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
Nmap scan report for 192.168.56.101  
Host is up (0.0011s latency).  
MAC Address: 08:00:27:44:30:BC (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
Nmap scan report for 192.168.56.102  
Host is up.  
Nmap done: 256 IP addresses (4 hosts up) scanned in 27.99 seconds  
(bruno@kali)-[~]  
$
```

Figure 3: nmap -sn ping sweep

Output: Four hosts respond (compared to three). Nmap also detects the local machine (Kali, .102), which arp-scan can't show.

1.3 SYN Scan on Metasploitable

SYN scan against the target to list open ports, with the output saved to a file.

```
nmap -sS -T4 192.168.56.101 -oN basic-scan.txt
```

```
(bruno@kali)-[~]
$ nmap -sS -T4 192.168.56.101 -oN basic-scan.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-13 07:53 EDT
Nmap scan report for 192.168.56.101
Host is up (0.0014s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8080/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:44:30:BC (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 14.10 seconds

(bruno@kali)-[~]
```

Figure 4: SYN scan result – 23 open ports on Metasploitable 2

Output: 23 open TCP ports (977 of the 1000 scanned came back closed), including classic Unix services (FTP, SSH, Telnet), web services (HTTP, Tomcat/AJP), and legacy remote access and database services. This shows a wide, dated attack surface.

1.4 Wireshark Capture

Filter used while running the scans above.

```
ip.addr == 192.168.56.101
```

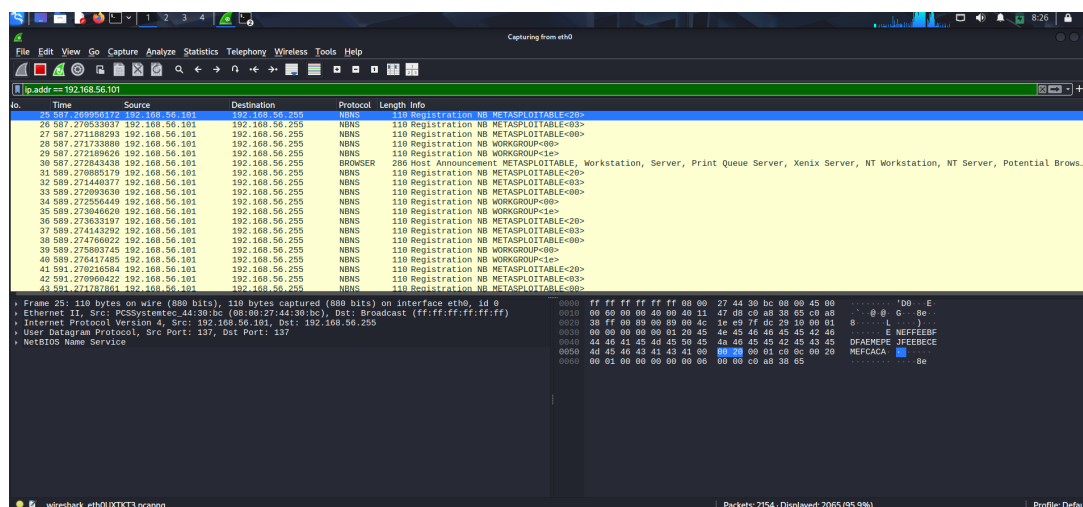


Figure 5: Wireshark capture showing NBNS/BROWSER traffic from Metasploitable

Output: NBNS name registrations and a BROWSER “Host Announcement” where Metasploitable identifies itself as METASPLOITABLE in workgroup WORKGROUP. This is Samba announcing itself.

2. Report Questions

1. Which hosts are alive on the network?

Four hosts: 192.168.56.1 (gateway), .100, .101 (Metasploitable), .102 (Kali). arp-scan only showed three because it can't see its own host. The Nmap ping sweep captured the fourth.

2. What open ports did you discover on Metasploitable 2?

Ports 21, 22, 23, 25, 53, 80, 111, 139, 445, 512, 513, 514, 1099, 1524, 2049, 2121, 3306, 5432, 5900, 6000, 6667, 8009, 8180 – 23 ports total.

3. What protocols and services do you suspect are running based on port numbers?

Port	Service
21	FTP (vsftpd)
22	SSH
23	Telnet
25	SMTP
53	DNS
80	HTTP (Apache)
111	rpcbind
139 / 445	Samba (SMB)
512–514	rexec / rlogin / rsh
1099	Java RMI
1524	ingreslock (Nmap identifies it as a bindshell)
2049	NFS
2121	FTP on an alternate port (ProFTPD)
3306	MySQL
5432	PostgreSQL
5900	VNC
6000	X11
6667	IRC (UnrealIRCd)
8009	AJP (Tomcat connector)
8180	Apache Tomcat

4. Describe the difference between ARP scan, ping sweep, and SYN scan.

Technique	Description
ARP scan	Layer 2, only works on the local subnet. Sends ARP requests and any live host must reply. Fast and reliable locally, but can't cross routers.
Ping sweep	Layer 3/4. Uses ICMP echo, TCP SYN to port 443, TCP ACK to port 80, and ICMP timestamp to check which hosts respond. Works across networks but can be blocked by firewalls.
SYN scan	Sends a TCP SYN to individual ports and reads the reply (SYN/ACK = open, RST = closed) without completing the handshake. Used to find open ports on a host already known to be alive, and it is stealthier than a full connect scan.

3. Command Summary

Command	Purpose
<code>sudo arp-scan -local</code>	Discover local hosts via ARP
<code>sudo arp-scan 192.168.56.0/24</code>	Same, on the full subnet
<code>nmap -sn 192.168.56.0/24</code>	Ping sweep
<code>nmap -sS -T4 192.168.56.101 -oN basic-scan.txt</code>	SYN port scan
Wireshark filter: <code>ip.addr == 192.168.56.101</code>	Watch scan traffic

Exercise 2: Service Enumeration & Version Detection

Objective

Perform deep service enumeration to identify running software versions and potential vulnerabilities.

Tools / Software

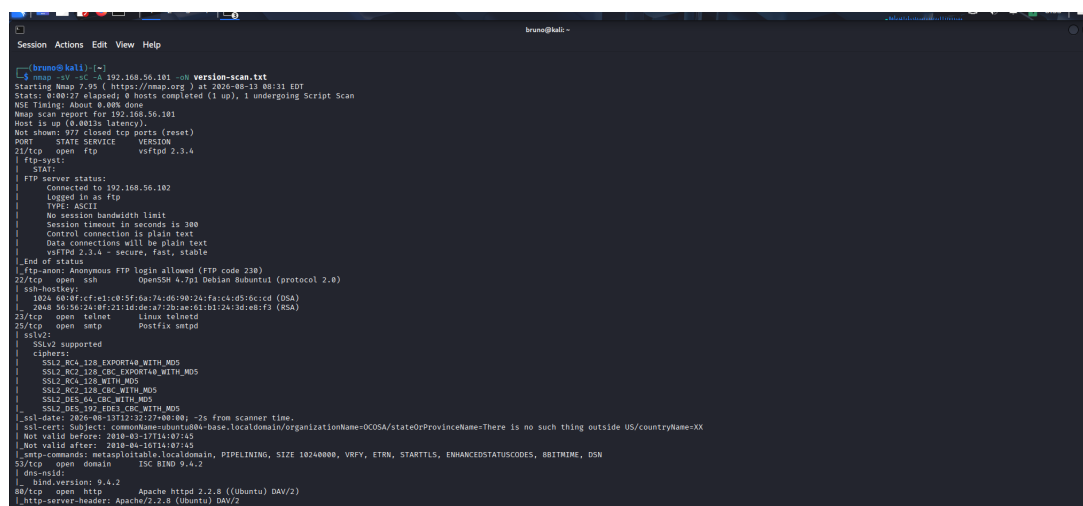
Kali: nmap (-sV, -sC, -A, -script vuln), whatweb, nikto.

Steps

2.1 Service Version Detection

Command: runs version detection, default scripts, and OS/aggressive fingerprinting together.

```
nmap -sV -sC -A 192.168.56.101 -oN version-scan.txt
```



```
bruno@kali: ~  
$ nmap -sV -sC -A 192.168.56.101 -oN version-scan.txt  
Starting Nmap 7.95 ( https://nmap.org ) at 2020-08-13 08:31 EDT  
Stats: 0:00:17 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan  
NSE Timing: About 9.00% done  
Nmap scan report for 192.168.56.101  
Host is up (4.001s latency).  
Not shown: 977 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp           vsftpd 2.3.4  
|_ftp-syst:  
|_  STAT  
|_  FTP server status:  
|_    Connected to 192.168.56.102  
|_    Logged in as ftp  
|_    TYPE: ASCII  
|_    No session bandwidth limit  
|_    Session timeout in seconds is 300  
|_    Control connection is plain text  
|_    Data connections will be plain text  
|_    vsftpd 2.3.4 - secure, fast, stable  
|_End of status  
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)  
22/tcp    open  ssh           OpenSSH 4.7p1 Debian Ubuntu (protocol 2.0)  
|_ssh-hostkey:  
|_  1024 80a5f1cf:rel:c05f6a7a:d09024:fa:ca:d5:6c:cd (DSA)  
|_  2048 56:56:7a:0f:21:1d:de:a7:2b:ae:03:b1:24:3d:e8:f3 (RSA)  
23/tcp    open  telnetd       Linux telnetd  
25/tcp    open  smtp          Postfix smtpd  
|_ssl:  
|_  SSLv2 supported  
|_  ciphers:  
|_    SSLv2_RC4_128_EXPORT40_WITH_MD5  
|_    SSLv2_RC2_128_CBC_EXPORT40_WITH_MD5  
|_    SSLv2_RC4_128_WITH_MD5  
|_    SSLv2_RC2_128_CBC_WITH_MD5  
|_    SSLv2_DES_64_CBC_WITH_MD5  
|_    SSLv2_DES_192_CBC_WITH_MD5  
|_  _ssl-date: 2020-08-13T12:32:12Z+00:00 -7s from scanner time.  
|_  _ssl-cert: Subject: commonName=ubuntu-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX  
|_  Not valid before: 2010-03-17T14:07:45  
|_  Not valid after: 2010-06-16T14:07:45  
|_  _smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN  
53/tcp    open  domain        ISC BIND 9.4.2  
|_dns-nsid:  
|_  _bind.version: 9.4.2  
80/tcp    open  http          Apache httpd 2.2.8 ((Ubuntu) DAV/2)  
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
```

Figure 6: nmap -sV -sC -A – service version and script scan

Output: vsftpd 2.3.4 on port 21 (anonymous login allowed), OpenSSH 4.7p1 Debian on port 22, Linux telnetd on port 23, Postfix smtpd on port 25 (weak SSLv2/export ciphers, self-signed cert naming `ubuntu804-base.localdomain`), ISC BIND 9.4.2 on port 53, Apache httpd 2.2.8 (Ubuntu) with DAV/2 on port 80. These are the exact versions to check against known CVEs. The screenshot stops at port 80; the full output for the remaining ports is in Appendix A.

2.2 Vulnerability Script Scan

Command: Nmap’s NSE “vuln” category actively tests each open port against known vulnerabilities.

```
nmap --script vuln -T4 192.168.56.101 -oN vuln-scan.txt
```

```

bruno@kali:~$ nmap -script vuln -i 192.168.56.101 --nmap-scan.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-13 09:24 EDT
Nmap scan report for 192.168.56.101
Host is up (4.803s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
|ftp-vsftpd-backdoor:
|  VULNERABLE:
|  vsftpd version 2.3.4 backdoor
|  State: VULNERABLE (Exploitable)
|  IDs: 810:48539 CVE:CVE-2011-2523
|  vsftpd version 2.3.4 backdoor, this was reported on 2011-07-04.
|  Disclosure date: 2011-07-03
|  Exploit results:
|  Shell command: id
|  Results: uid=0(root) gid=0(root)
|  References:
|  https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|  http://ccayheastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|  https://www.securityfocus.com/bid/48539
|  https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
|ssl-dh-param:
|  VULNERABLE:
|  Anonymous Diffie-Hellman Key Exchange MITM Vulnerability
|  State: VULNERABLE
|  Transport Layer Security (TLS) services that use anonymous
|  Diffie-Hellman key exchange only provide protection against passive
|  eavesdropping, and are vulnerable to active man-in-the-middle attacks
|  which could completely compromise the confidentiality and integrity
|  of any data exchanged over the resulting session.
|  Check results:
|  ANONYMOUS DH GROUP 1
|  Cipher Suite: TLS_DH_anon_WITH_RC4_128_MD5
|  Modulus Type: Safe prime
|  Modulus Source: postfix builtin
|  Modulus Length: 1024
|  Generator Length: 8
|  Public Key Length: 1024
|  References:
|  https://www.ietf.org/rfc/rfc2246.txt
|  Transport Layer Security (TLS) Protocol DHE_EXPORT Ciphers Downgrade MITM (Logjam)

```

Figure 7: nmap --script vuln – vulnerability scan

Output: Confirms the vsftpd 2.3.4 backdoor is exploitable (CVE-2011-2523). The script triggers the backdoor shell, returning uid=0(root) gid=0(root). It also flags SMTP’s anonymous Diffie-Hellman key exchange as vulnerable to MITM and Logjam-style downgrade. The screenshot shows only the first part of the scan; further ports are flagged further down, and the full output is in Appendix B. Note: the screenshot is from an earlier run of the same command (09:24 EDT); Appendix B is the 16:54 EDT run, with identical findings.

2.3 UDP Scan

Command: scans UDP ports 1 to 1000. These are often skipped but can reveal extra attack surface.

```
nmap -sU -p 1-1000 192.168.56.101
```

```

bruno@kali:~$ nmap -sU -p 1-1000 192.168.56.101
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-13 09:33 EDT
Nmap scan report for 192.168.56.101
Host is up (0.0015s latency).
Not shown: 994 closed udp ports (port-unreach)
PORT      STATE SERVICE
53/udp    open  domain
69/udp    open|filtered tftp
111/udp   open  rpcbind
137/udp   open  netbios-ns
138/udp   open|filtered netbios-dgm
906/udp   open|filtered unknown
MAC Address: 08:00:27:44:30:BC (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 1084.67 seconds

```

Figure 8: nmap -sU -p 1-1000 – UDP scan

Output: Six UDP ports are open or open|filtered: 53 (DNS), 69 (TFTP), 111 (rpcbind), 137 (NetBIOS-NS), 138 (NetBIOS-DGM), 906 (unknown). These are extra services not visible in the TCP-only scans.

2.4 Web Service Enumeration

Command: whatweb fingerprints the web stack. Nikto runs an automated web vulnerability scan.

```
whatweb 192.168.56.101
nikto -h 192.168.56.101
```

Figure 9: whatweb – web technology fingerprinting

Output: Apache 2.2.8 (Ubuntu) with DAV/2, PHP 5.2.4-2ubuntu5.10, page title “Metasploitable2 - Linux.” This confirms the Nmap-scan versions.

```

[*] (root@kali) ~#
[*] nikto -s 192.168.56.101
[*] Nikto v2.5.6

Target IP:      192.168.56.101
Target Hostname: 192.168.56.101
Target Port:    80
Start Time:     2026-08-13 10:00:21 (GMT+4)

Server: Apache/2.2.8 (Ubuntu) DAV/2
[-]: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
[-]: The anti-clickjacking X-FRAME-OPTIONS header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
[-]: The X-Content-Type-Options header is set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/miss-x-content-type-options-header/
Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
[-]: Server version header 'con' found, with content: '1'.
[-]: Server version negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php; http://www.wisec.it/sectou.php?id=6998bde59d51.htm
[-]: /exchange_xref/libcloadcom/vulnerabilities/8275
[-]: Web Server returns a valid response with link HTTP methods which can cause false positives.
[-]: Web TRACE method is active which suggests the host is vulnerable to XSS. See: https://wasp.org/www-community/attacks/Cross-Site_Tracing
phpinfo.php: Output from the phpinfo() function was found.
./doc/: Directory indexing found.
./doc/: The ./doc directory is browsable. This may be /etc/passwd. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0679
[-]: /PHPMP0572AP-KCZJ-1I63-A3AP-CF788C1000B0.PHP Reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-122184
[-]: /PHPMP0572AP-KCZJ-1I63-A3AP-CF788C1000B0.PHP Reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-122184
[-]: /PHPMP0580A31-Q2H-1Q2E-A769-0BA0AA8AC2A1.PHP Reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-122184
[-]: /PHPMP0580A31-Q2H-1Q2E-A769-0BA0AA8AC2A1.PHP Reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-122184
[-]: /phpmyadmin/phpmyadmin.php: phpmyadmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
[-]: /phpmyAdmin/ChangeLog: Server may leak info via ETags, header found with file /phpmyAdmin/ChangeLog, inode: 92462, size: 40540, time: Tue Dec 9 12:24:10 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1618
[-]: /rest/: Directory indexing found.
[-]: This may again be interesting.
[-]: /wpinfo.php: WP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CVE-552
./icms/: Directory indexing found.
./icms/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsrname/
./icms/admin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
./icms/admin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
./new-config.php: new-config.php file found. This file contains the credentials.
[0/1] requests : 0 errors(s) and 27 item(s) reported on remote host
End Time:    2026-08-13 10:01:13 (GMT+4) (CR remote)

1 host(s) tested
[*] (root@kali) ~#
```

Figure 10: nikto – web server vulnerability scan

Output: Twenty-seven findings across 8910 requests. These include missing security headers (X-Frame-Options, X-Content-Type-Options), HTTP TRACE enabled, mod_negotiation enabled (filename brute-forcing), browsable /doc and /test, exposed phpinfo(), and unrestricted phpMyAdmin install.

Key Services to Identify on Metasploitable 2

Port	Service	Version
21	FTP	vsftpd 2.3.4
22	SSH	OpenSSH 4.7p1 Debian 8ubuntu1
23	Telnet	Linux telnetd
80	HTTP	Apache 2.2.8
445	SMB	Samba smbd 3.0.20-Debian
3306	MySQL	MySQL 5.0.51a-3ubuntu5

Report Questions

1. **What version of vsftpd is running? What CVE is associated with this version?**
vsftpd 2.3.4 on port 21 (Fig. 6). The vuln scan reports it as CVE-2011-2523 (BID:48539) with state VULNERABLE (Exploitable), and the shell command it runs returns uid=0(root) gid=0(root) (Fig. 7).
2. **What version of Apache is running? What vulnerabilities affect this version?**

Apache httpd 2.2.8 (Ubuntu) with DAV/2 on port 80, confirmed by nmap, whatweb, and nikto. Nikto flags it as outdated and notes 2.2.34 as the EOL of the 2.x branch. It also reports missing security headers, HTTP TRACE enabled, mod_negotiation enabled, browsable /doc and /test, an exposed phpinfo() page, and an unrestricted phpMyAdmin install (Fig. 10).

3. What is the operating system of the target machine?

Linux, Ubuntu 8.04 (Hardy Heron). Nmap's OS detection reports Linux 2.6.9 to 2.6.33, the SMTP certificate commonName is ubuntu804-base.localdomain (Fig. 6), and smb-os-discovery returns Unix (Samba 3.0.20-Debian) with hostname metasploitable (Appendix A).

4. Which services appear to be the most vulnerable based on version information?

Three services carry confirmed backdoors or remote code execution:

- vsftpd 2.3.4 on port 21, the worst of the three. CVE-2011-2523, state VULNERABLE (Exploitable), and the scan already returns uid=0(root) gid=0(root).
- UnrealIRCd on port 6667. The irc-unrealircd-backdoor script reports a trojaned version.
- Java RMI on port 1099. The rmi-vuln-classloader script reports the default registry configuration as VULNERABLE to remote code execution.

After those, the TLS services: SMTP and PostgreSQL are both flagged for POODLE (CVE-2014-3566) and weak Diffie-Hellman groups, SMTP additionally for anonymous key exchange and Logjam (CVE-2015-4000), and PostgreSQL for CCS injection (CVE-2014-0224, risk factor High). The web stack is broad rather than deep: possible SQL injection and CSRF across /dvwa, /mutillidae and /twiki, TRACE enabled, Slowloris likely on both 80 and 8180, and /phpMyAdmin, /phpinfo.php and /doc left reachable. Telnet (plaintext credentials) and the r-services on 512 to 514 (minimal auth) remain weak points. Full output in Appendix B.

Command Summary

Command	Purpose
nmap -sV -sC -A 192.168.56.101 -oN version-scan.txt	Service version, default-script, and OS fingerprinting
nmap -script vuln -T4 192.168.56.101 -oN vuln-scan.txt	Active NSE vulnerability scan
nmap -sU -p 1-1000 192.168.56.101	UDP port scan (ports 1 to 1000)
whatweb 192.168.56.101	Web technology fingerprinting
nikto -h 192.168.56.101	Web server vulnerability scan

Exercise 3: Web Application Enumeration & OWASP Juice Shop

Objective

Enumerate web applications, discover hidden directories, and identify web vulnerabilities.

Tools / Software

Kali: Docker (for Juice Shop), Gobuster, Sublist3r, Burp Suite (Proxy/Intruder), Firefox. Target: the Juice Shop container on the Kali host at 192.168.56.102:3000.

Steps

3.1 Launch OWASP Juice Shop

Juice Shop is pulled and run as a detached Docker container with port 3000 published. The run command pulls the image automatically if it is not already present.

```
docker pull bkimminich/juice-shop
docker run -d -p 3000:3000 bkimminich/juice-shop
```

Access it at <http://192.168.56.102:3000>.

A terminal window with a dark background. The prompt is 'bruno@kali:~'. The user enters 'sudo docker run -d -p 3000:3000 bkimminich/juice-shop'. The terminal shows the command being executed and the container ID 'aeb6a7e95be29a6033f1294e413a56c9deeace30b19a43d4aebefc48d5187b25'.

Figure 11: docker run – starting the Juice Shop container

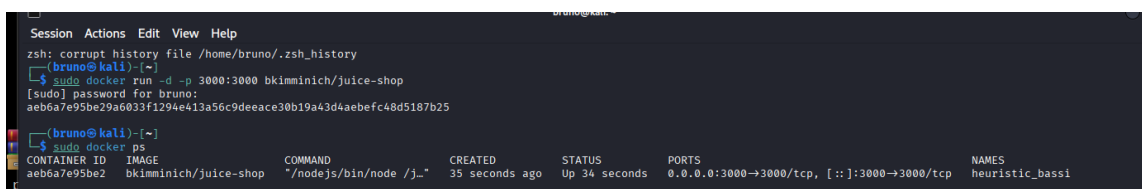
A terminal window showing the output of 'docker ps'. The prompt is 'bruno@kali:~'. The user enters 'sudo docker ps'. The output shows a table with columns: CONTAINER ID, IMAGE, COMMAND, CREATED, STATUS, PORTS, and NAMES. The container 'aeb6a7e95be2' is listed as running, with port 3000 mapped to 3000/tcp, and named 'heuristic_bassi'.

Figure 12: docker ps – container running with port 3000 mapped

Output: The container starts and **docker ps** confirms it is up, with 3000/tcp mapped to the host. The application is now reachable at <http://192.168.56.102:3000>.

3.2 Web Application Enumeration

Gobuster brute-forces directory and file names; Sublist3r looks for subdomains.

```
gobuster dir -u http://192.168.56.102:3000 -w /usr/share/wordlists/dirbuster/directory
-list-2.3-medium.txt
sublist3r -d juice-shop.local
```

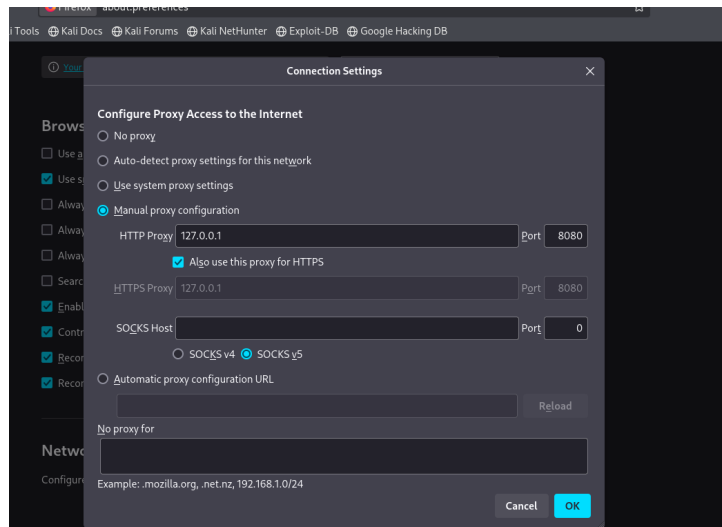



Figure 15: Firefox – manual proxy set to 127.0.0.1:8080

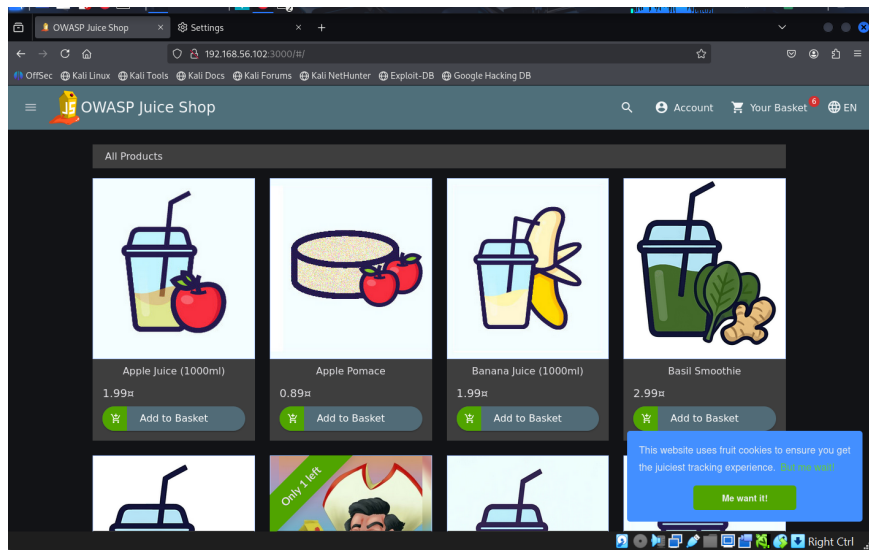


Figure 16: OWASP Juice Shop loaded through the proxy

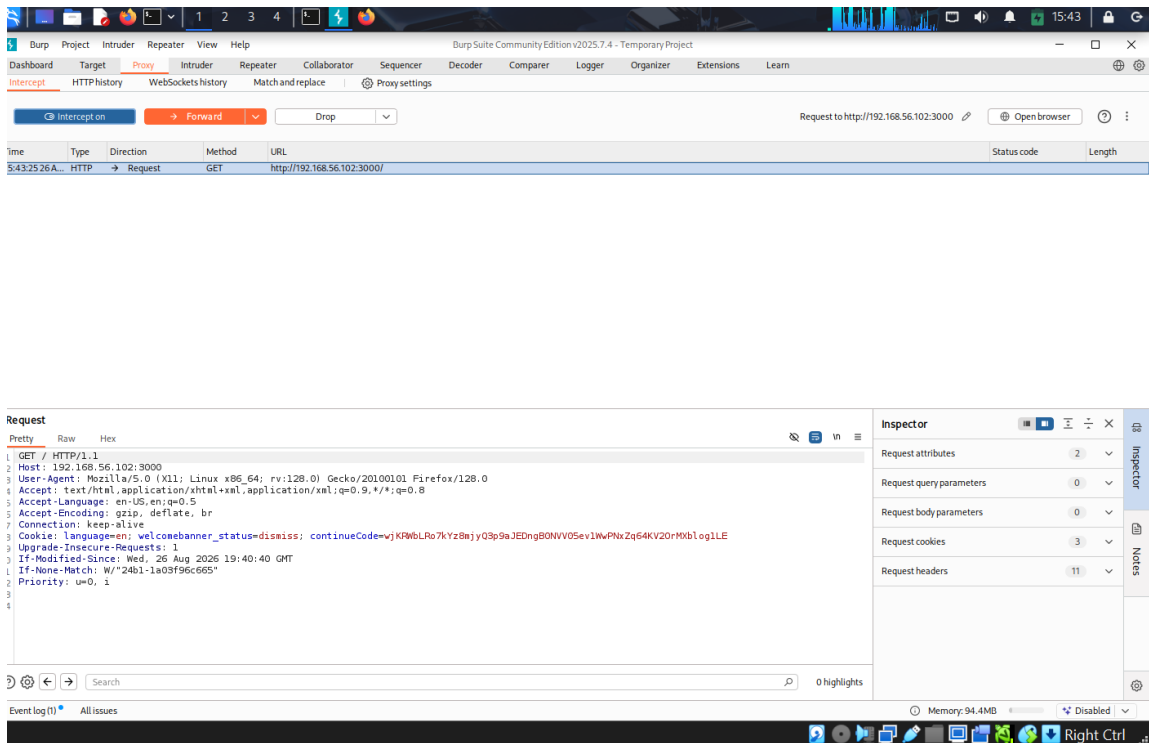


Figure 17: Burp Proxy – intercepting a request to Juice Shop

Output: With the proxy set, browsing the app routes through Burp, which shows each request and response. This is the setup for the manual tests that follow.

3.4 Manual Vulnerability Testing

SQL Injection. The login form is submitted with an SQL payload in the email field instead of a real address.

Email: ' OR 1=1--
Password: 123456

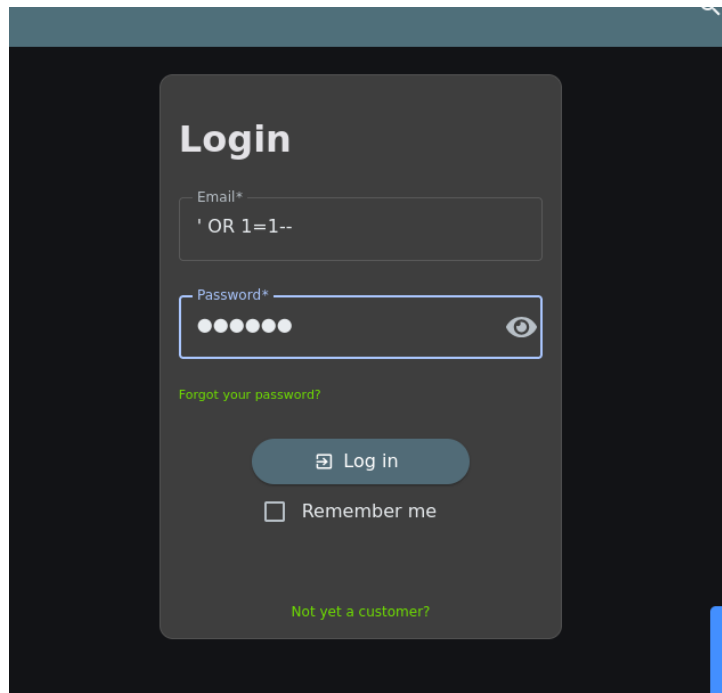


Figure 18: Juice Shop login with the SQL injection payload in the email field

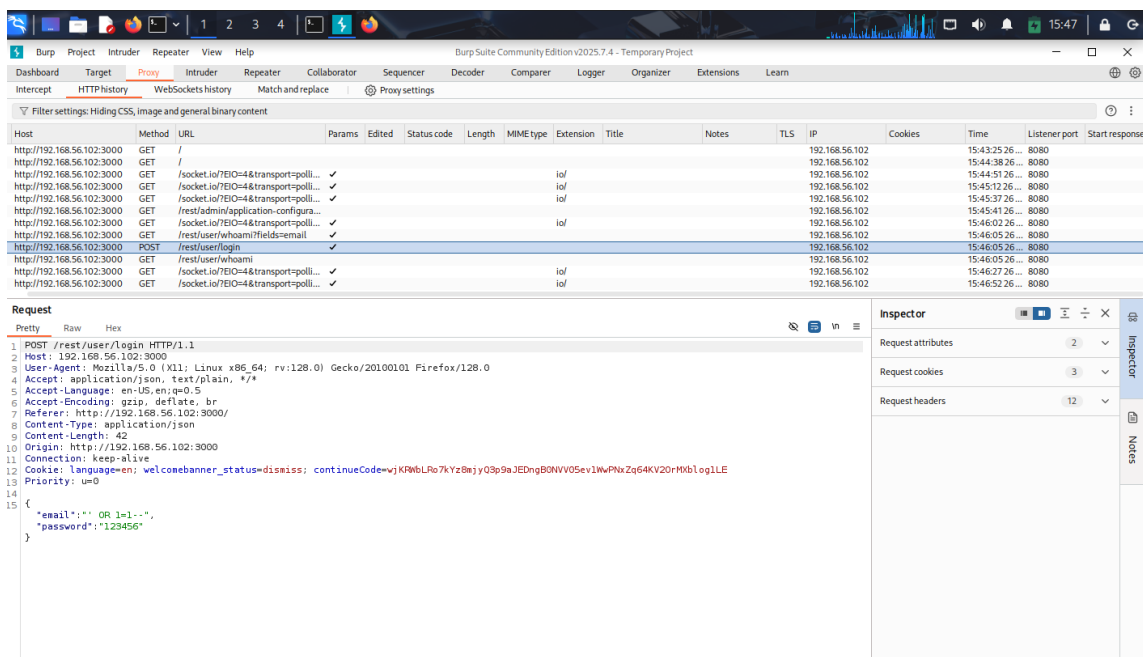


Figure 19: Burp – the login POST with the injected email

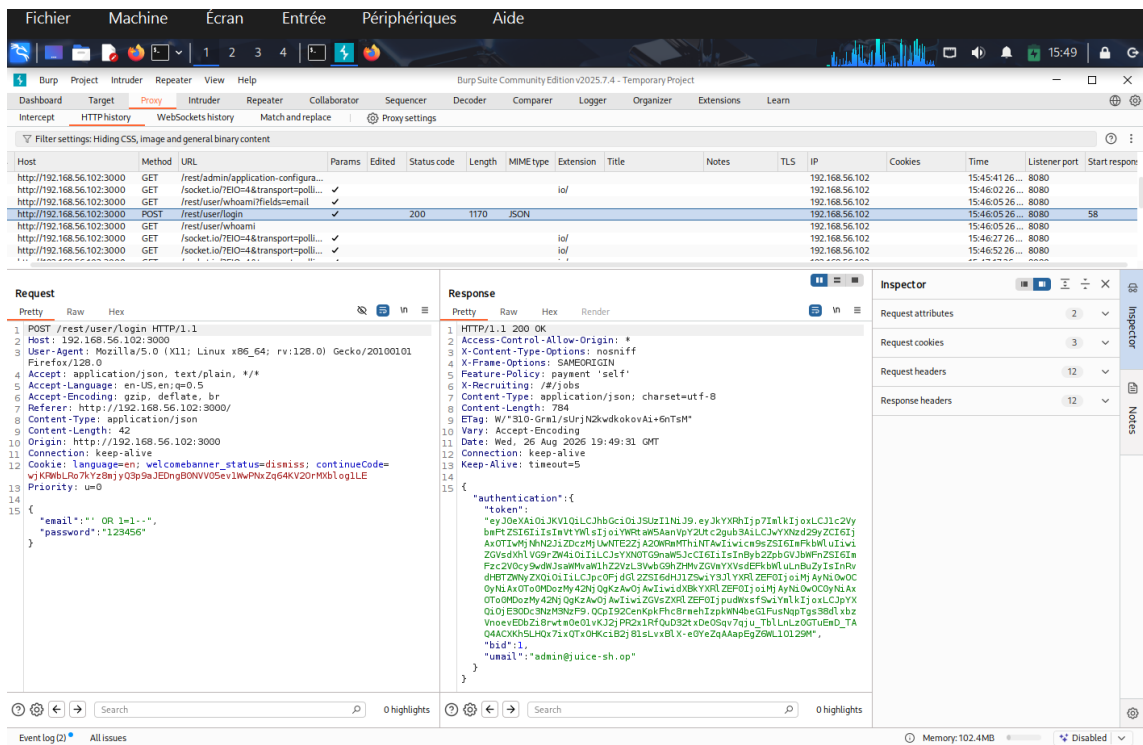


Figure 20: Burp – 200 response with a session token for the admin account

Output: The request is POST /rest/user/login with the body {"email":"' OR 1=1--", "password":"123456"}. The injected ' OR 1=1-- makes the login query always true and comments out the rest, so the database returns the first user. The server replies 200 OK with a valid authentication token (a JWT) and "umail":"admin@juice-sh.op". That is a full authentication bypass: the login succeeds as the admin account without a valid password.

XSS. A script payload is placed in the product search box.

```
<script>alert('XSS')</script>
```

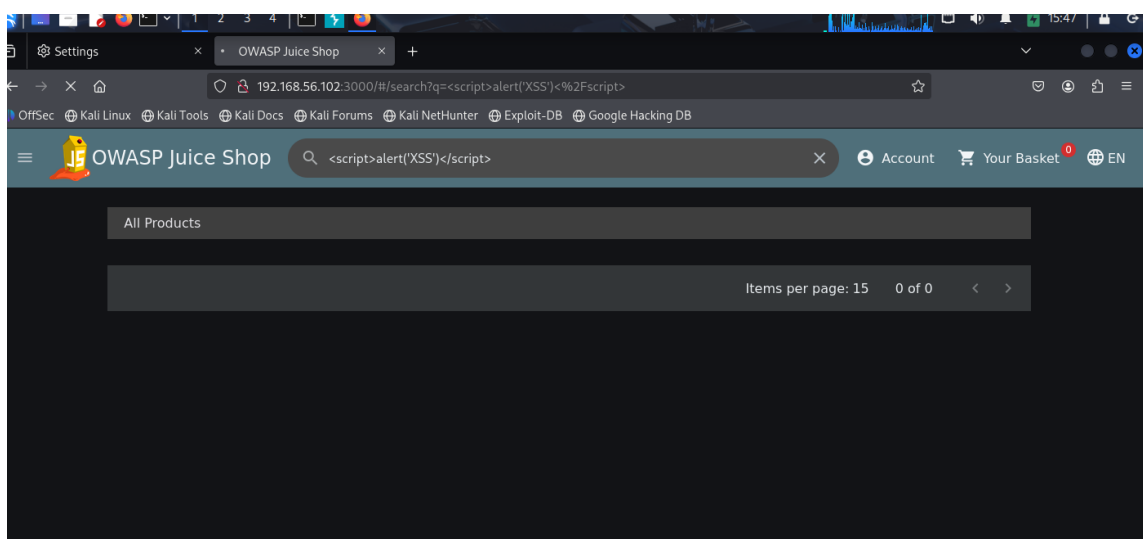


Figure 21: Juice Shop search with the XSS payload in the query

Output: The payload lands in the search?q= parameter and is reflected back into the search

field, and the product list shows 0 of 0 results. In this capture no alert box is shown executing, which is consistent with Angular escaping a plain `<script>` tag. So the payload is reflected but not confirmed to execute here; the search parameter is the injection point to investigate further with a vector Angular does not neutralise.

Broken Authentication (JWT). The login response above (Figure 20) is also the evidence for this test. The server returns the session as a JSON Web Token in the response body, which Burp shows in full. Because the token is visible in the proxy, it can be copied, decoded, and inspected, and here it was obtained through the SQL injection rather than a real login, which shows the authentication can be bypassed end to end.

Report Questions

1. What hidden directories or files did you discover?

Directory brute-forcing with gobuster did not return usable results, because Juice Shop answers HTTP 200 for every path (the wildcard behaviour in Figure 13), so no directory stood out as real. Browsing the app through Burp was more useful: the proxy history exposes real API endpoints, including `/rest/user/login`, `/rest/user/whoami`, `/rest/user/whoami?fields=email` and `/rest/admin/application-configuration` (visible in Figure 20). Those are the paths worth following up, not anything gobuster produced.

2. Were you able to bypass the login using SQL injection?

Yes. Submitting `' OR 1=1--` in the email field returned 200 OK with a valid JWT for `admin@juice-sh.op` (Figure 20), so the login was bypassed and the session belongs to the admin account, with no valid password supplied.

3. What sensitive information is exposed in API responses?

The login response leaks the full session token (JWT) and the account email `admin@juice-sh.op` directly in the body. The response headers also set `Access-Control-Allow-Origin: *`, and the proxy history shows endpoints such as `whoami` and `application-configuration` that return account and configuration data.

4. What security misconfigurations can you identify?

The login query is built from unsanitised input, which is what allows the SQL injection bypass. The session token is handed back in the response body rather than a hardened cookie. Cross-origin requests are allowed from any origin (`Access-Control-Allow-Origin: *`). Together these show input handling, session handling, and CORS all left in an insecure state.

Command Summary

Command	Purpose
<code>docker pull bkimminich/juice-shop</code>	Fetch the Juice Shop image
<code>docker run -d -p 3000:3000 bkimminich/juice-shop</code>	Start the container
<code>gobuster dir -u http://192.168.56.102:3000 -w directory-list-2.3-medium.txt</code>	Directory enumeration
<code>sublist3r -d juice-shop.local</code>	Subdomain enumeration
Firefox proxy 127.0.0.1:8080	Route traffic through Burp
<code>' OR 1=1--</code> in the login email	SQL injection login bypass
<code><script>alert('XSS')</script></code> in search	Reflected XSS test

Exercise 4: Credential Attacks & Brute Force

Objective

Perform password attacks against network services and web applications.

Tools / Software

Kali: Hydra (SSH/FTP), Burp Suite Intruder, enum4linux, smbclient. Target: Metasploitable 2 at 192.168.56.101, attacking from Kali at 192.168.56.102.

Steps

4.1 SSH Brute Force with Hydra

Hydra tries username and password combinations against the live SSH service. The first run targets a single user with the rockyou wordlist; the second swaps in Metasploit's default-users list.

```
hydra -l msfadmin -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.101
hydra -L /usr/share/wordlists/metasploit/default_users.txt -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.101
```

For each service the attack is shown twice. The left screenshot runs against the unmodified rockyou list to show it working at scale. The right screenshot runs against a copy of the list with the known password placed near the top, so the run reaches it quickly and Hydra prints the recovered credential. This is a common way to demonstrate a successful crack without waiting for the whole list.

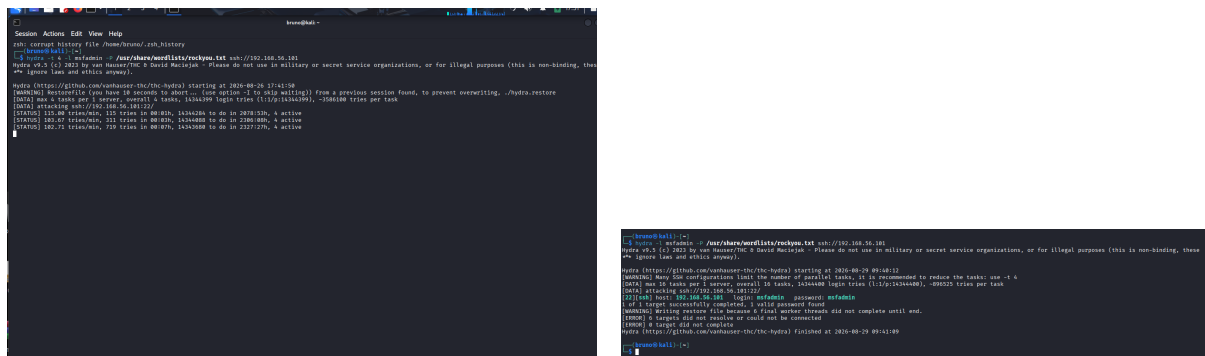


Figure 22: hydra SSH, single user. Left: unmodified rockyou, still running. Right: password seeded near the top, credential found.

Output: On the left, the unmodified rockyou run reports its scale (about 14 million entries, an estimate in the thousands of hours) and returns nothing in the window. On the right, with **msfadmin** placed near the top of the list, the same command finishes in about a minute (09:40:12 to 09:41:09) and reports **login: msfadmin password: msfadmin**, one valid password found.

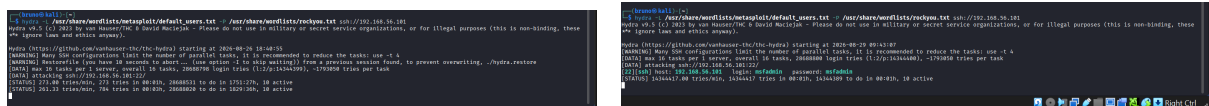


Figure 23: hydra SSH, default-users list. Left: unmodified rockyou. Right: password seeded near the top, credential found.

Output: The default-users run multiplies the work (16 tasks, about 28 million combinations). On the left it only reports progress; on the right, with the password near the top, Hydra again returns login: **msfadmin** password: **msfadmin** for SSH.

4.2 FTP Brute Force

The same approach against FTP on port 21.

```
hydra -l msfadmin -P /usr/share/wordlists/rockyou.txt ftp://192.168.56.101
```

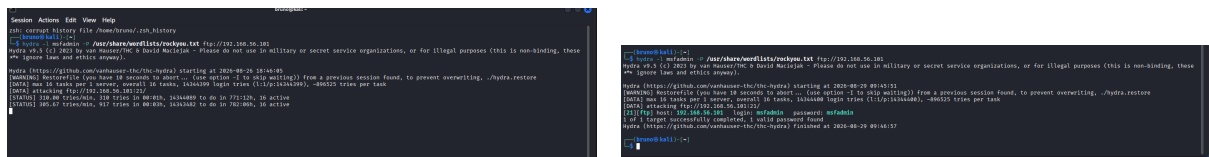


Figure 24: hydra FTP. Left: unmodified rockyou, still running. Right: password seeded near the top, credential found.

Output: On the left, the unmodified rockyou run works through the FTP service at about 300 tries per minute and returns nothing in the window. On the right, with **msfadmin** near the top of the list, the same command finishes in about a minute (09:45:51 to 09:46:57) and reports login: **msfadmin** password: **msfadmin**, one valid password found.

4.3 Web Login Brute Force with Burp Suite Intruder

Metasploitable also hosts several web apps, including DVWA. The landing page lists them and prints the default **msfadmin/msfadmin** credentials.

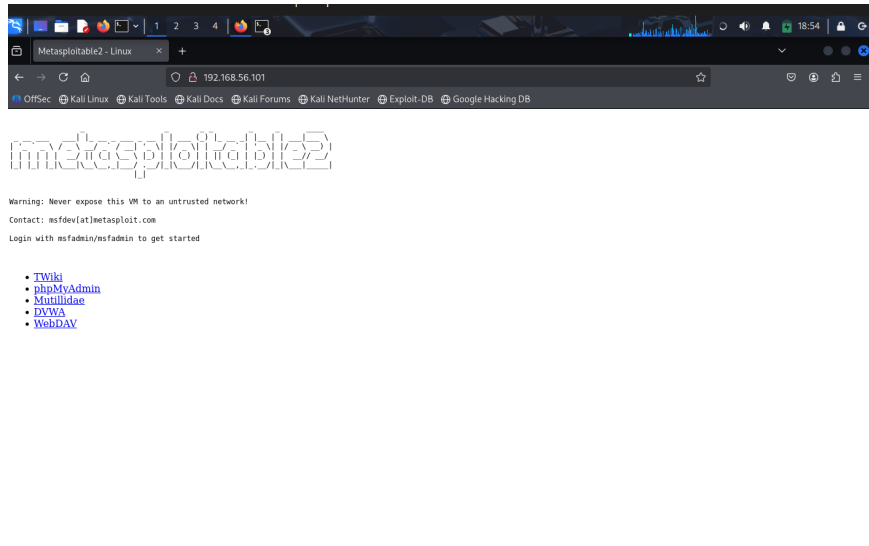


Figure 25: Metasploitable landing page listing the hosted web apps

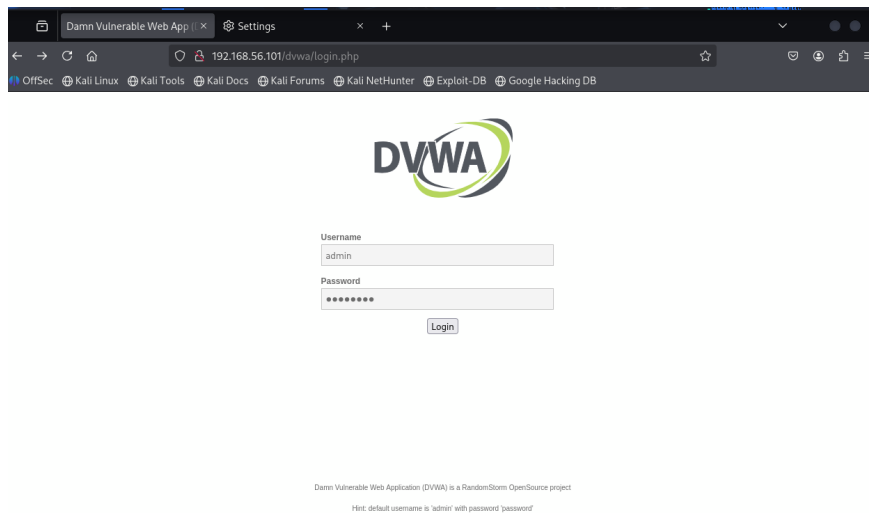


Figure 26: DVWA login form at /dwa/login.php; the hint gives the default admin/password

A login attempt was captured in Burp so the request could be reused. The proxy history shows the POST to /dwa/login.php.

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn														
Intercept HTTP history WebSockets history Match and replace Proxy settings														
Filter settings: Hiding CSS, image and general binary content														
#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies
1	http://192.168.56.101	GET	/phpMyAdmin/										192.168.56.101	19:01:20 26... 8080
2	http://192.168.56.101	GET	/dwa/										192.168.56.101	19:03:34 26... 8080
3	http://192.168.56.101	GET	/dwa/										192.168.56.101	19:03:39 26... 8080
4	http://192.168.56.101	POST	/dwa/login.php		✓			HTML	php				192.168.56.101	19:05:02 26... 8080

Figure 27: Burp proxy history – captured DVWA login request

The request was sent to Intruder and both the username and password fields were marked as payload positions.

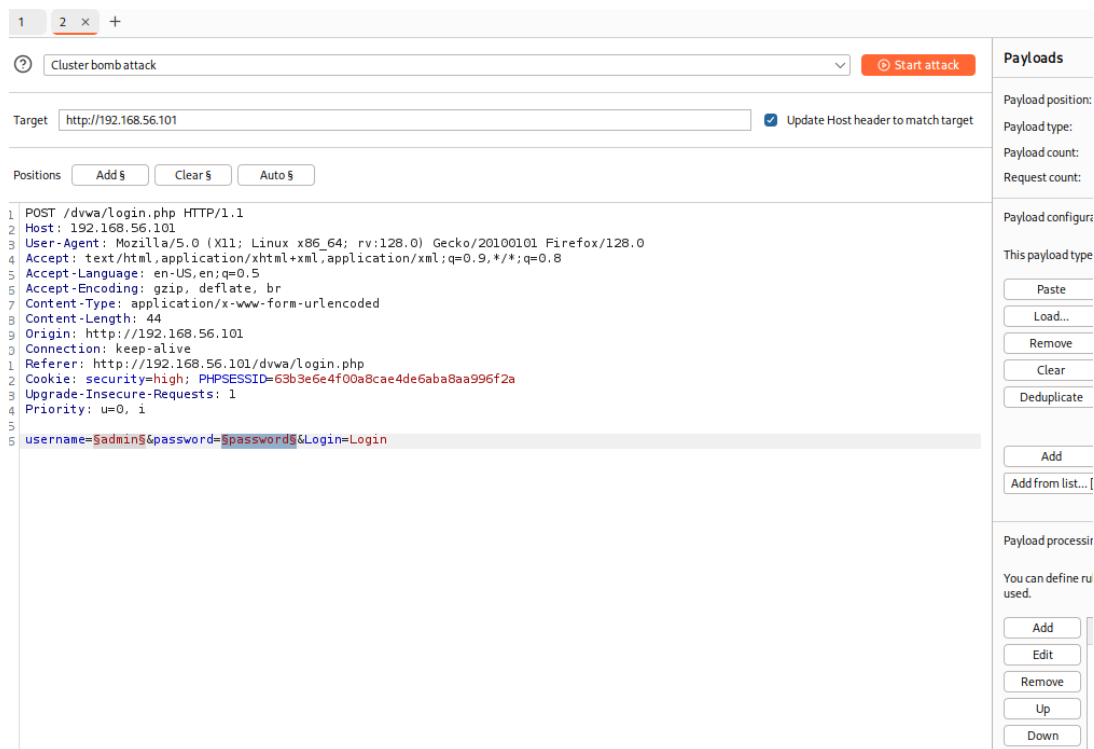


Figure 28: Burp Intruder – cluster-bomb positions on the username and password fields

A cluster-bomb attack was used so every username is tried against every password. The first position holds a short user list, the second a short password list.

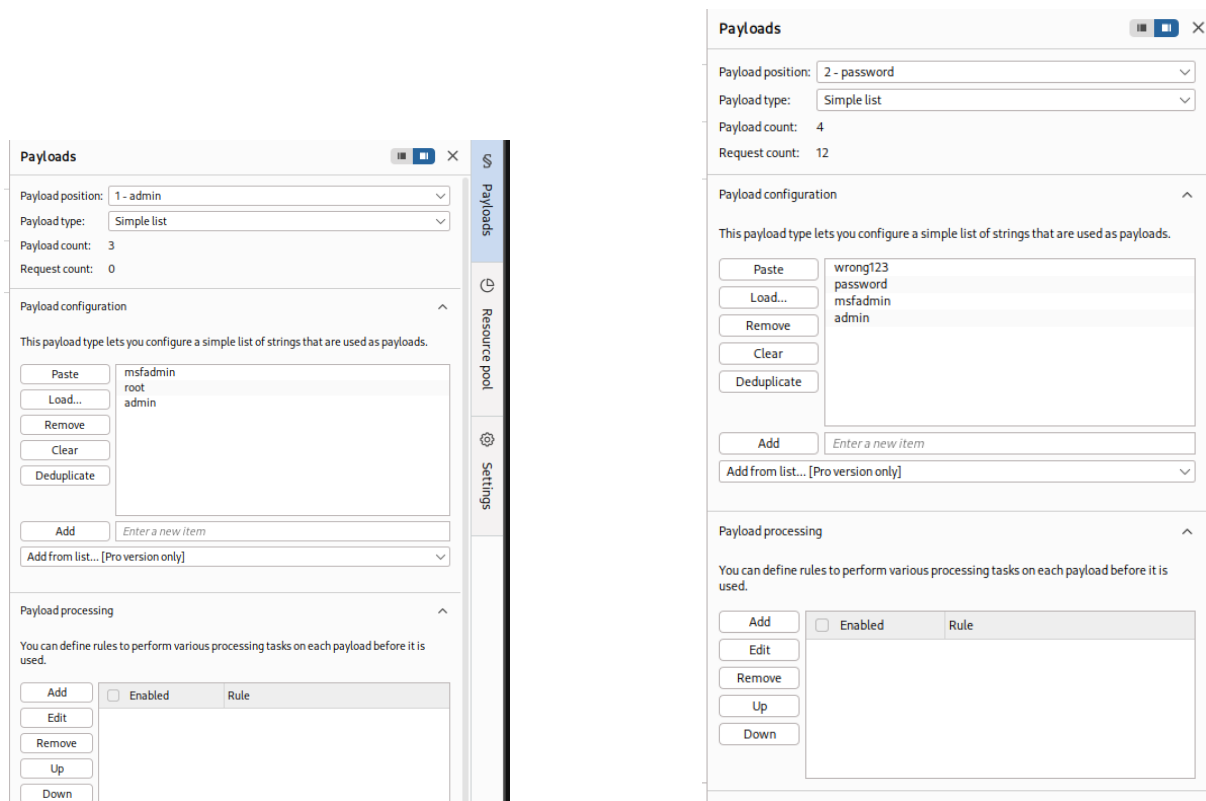


Figure 29: Burp Intruder payload sets – usernames (left) and passwords (right)

Attack Save		2. Intruder attack of http://192.168.56.101						
2. Intruder attack of http://192.168.56.101		Attack ▾						
Results Positions								
Capture filter: Capturing all items		Ap						
View filter: Showing all items								
Request	Payload 1	Payload 2	Status code	Response received	Error	Timeout	Length	Comment
0			302	27			392	
1	msfadmin	wrong123	302	18			392	
2	root	wrong123	302	16			392	
3	admin	wrong123	302	11			391	
4	msfadmin	password	302	16			391	
5	root	password	302	25			392	
6	admin	password	302	24			392	
7	msfadmin	msfadmin	302	16			391	
Request Response								
Pretty Raw Hex Render								
1 HTTP/1.1 302 Found								
2 Date: Sun, 30 Aug 2026 20:15:28 GMT								
3 Server: Apache/2.2.8 (Ubuntu) DAV/2								
4 X-Powered-By: PHP/5.2.4-2ubuntu5.10								
5 Expires: Thu, 19 Nov 1981 08:52:00 GMT								
6 Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0								
7 Pragma: no-cache								
8 Location: index.php								
9 Content-Length: 0								
10 Keep-Alive: timeout=15, max=100								
11 Connection: Keep-Alive								
12 Content-Type: text/html								
13								
14								

Figure 30: Burp Intruder results – the admin/password request returns Location: index.php, a successful login

Output: With three usernames against four passwords, the cluster-bomb attack sends twelve requests. Every one returns HTTP 302, so the status column alone does not separate a hit from a miss, and the length column (391 to 392) only tracks the payload length. The signal is the Location header in each response. A failed DVWA login redirects back to `login.php`; the `admin/password` request (row 6) instead returns `Location: index.php`, which is DVWA redirecting a successful login to the dashboard. So the attack recovers the valid credential, `admin/password`, which also matches the hint on the login page. The request still carries a `security=high` cookie; the login form accepts the correct pair regardless.

4.4 SMB Enumeration

`enum4linux` queries the target's SMB service for accounts, shares, and policy; `smbclient` lists the shares directly.

```
enum4linux -a 192.168.56.101
smbclient -L //192.168.56.101 -U msfadmin
```

```

Session Actions Edit View Help
bruno@kali:~$ (bruno@kali)-[~]
└─$ enum4linux -a 192.168.56.101
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Wed Aug 26 19:33:44 2026

----- ( Target Information ) -----
Target ..... 192.168.56.101
RID Range ..... 500-599,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

----- ( Enumerating Workgroup/Domain on 192.168.56.101 ) -----

[*] Got domain/workgroup name: WORKGROUP

----- ( Nbtstat Information for 192.168.56.101 ) -----

Looking up status of 192.168.56.101
METASPLOITABLE <00> - B <ACTIVE> Workstation Service
METASPLOITABLE <03> - B <ACTIVE> Messenger Service
METASPLOITABLE <20> - B <ACTIVE> File Server Service
\\_._MSKROWSE_... <03> - <GROUP> B <ACTIVE> Master Browser
WORKGROUP <00> - <GROUP> B <ACTIVE> Domain/Workgroup Name
WORKGROUP <1d> - B <ACTIVE> Master Browser
WORKGROUP <1e> - <GROUP> B <ACTIVE> Browser Service Elections
MAC Address = 00-00-00-00-00-00

----- ( Session Check on 192.168.56.101 ) -----

[*] Server 192.168.56.101 allows sessions using username '', password ''

----- ( Getting domain SID for 192.168.56.101 ) -----

Domain Name: WORKGROUP
Domain Sid: (NULL SID)

[*] Can't determine if host is part of domain or part of a workgroup

----- ( OS information on 192.168.56.101 ) -----

```

Figure 31: enum4linux – target information and NetBIOS lookup

Output: The target answers as METASPLOITABLE in workgroup WORKGROUP and allows a session with a blank username and password (a null session), which is what lets the rest of the enumeration run without credentials.

```

Session Actions Edit View Help
bruno@kali:~$ [E] Can't get OS info with smbclient

[*] Got OS info for 192.168.56.101 from srvinfo:
METASPLOITABLE Wk Sv Prq Uxr NT SNT metasploitable server (Samba 3.0.20-Debian)
platform_id : 500
os version : 4.9
server type : 0-9a83

----- ( Users on 192.168.56.101 ) -----

index: 0x1 RID: 0x3f2 acb: 0x00000011 Account: games Name: games Desc: (null)
index: 0x2 RID: 0x1f5 acb: 0x00000011 Account: nobody Name: nobody Desc: (null)
index: 0x3 RID: 0x4ba acb: 0x00000011 Account: bind Name: (null) Desc: (null)
index: 0x4 RID: 0x402 acb: 0x00000011 Account: proxy Name: proxy Desc: (null)
index: 0x5 RID: 0x4ba acb: 0x00000011 Account: syslog Name: (null) Desc: (null)
index: 0x6 RID: 0xbba acb: 0x00000010 Account: user Name: just a user,ill, Desc: (null)
index: 0x7 RID: 0x42a acb: 0x00000011 Account: www-data Name: www-data Desc: (null)
index: 0x8 RID: 0x208 acb: 0x00000011 Account: root Name: root Desc: (null)
index: 0x9 RID: 0x3fa acb: 0x00000011 Account: news Name: news Desc: (null)
index: 0xa RID: 0x4c0 acb: 0x00000011 Account: postgres Name: PostgreSQL administrator, Desc: (null)
index: 0xb RID: 0x2ec acb: 0x00000011 Account: bin Name: bin Desc: (null)
index: 0xc RID: 0x3f8 acb: 0x00000011 Account: mail Name: mail Desc: (null)
index: 0xd RID: 0x4c6 acb: 0x00000011 Account: distccd Name: (null) Desc: (null)
index: 0xe RID: 0x4ca acb: 0x00000011 Account: proftpd Name: (null) Desc: (null)
index: 0xf RID: 0x4b2 acb: 0x00000011 Account: dhcp Name: (null) Desc: (null)
index: 0x10 RID: 0x3ea acb: 0x00000011 Account: daemon Name: daemon Desc: (null)
index: 0x11 RID: 0x4b8 acb: 0x00000011 Account: sshd Name: (null) Desc: (null)
index: 0x12 RID: 0x3fa acb: 0x00000011 Account: man Name: man Desc: (null)
index: 0x13 RID: 0x3f9 acb: 0x00000011 Account: lp Name: lp Desc: (null)
index: 0x14 RID: 0x4c2 acb: 0x00000011 Account: mysql Name: MySQL Server, Desc: (null)
index: 0x15 RID: 0x43a acb: 0x00000011 Account: gnats Name: Gnats Bug-Reporting System (admin) Desc: (null)
index: 0x16 RID: 0x4b0 acb: 0x00000011 Account: libuuid Name: (null) Desc: (null)
index: 0x17 RID: 0x42c acb: 0x00000011 Account: backup Name: backup Desc: (null)
index: 0x18 RID: 0xb0b acb: 0x00000010 Account: msfadmin Name: msfadmin, Desc: (null)
index: 0x19 RID: 0x4c8 acb: 0x00000011 Account: telnetd Name: (null) Desc: (null)
index: 0x1a RID: 0x3ee acb: 0x00000011 Account: sys Name: sys Desc: (null)
index: 0x1b RID: 0x4b6 acb: 0x00000011 Account: klog Name: (null) Desc: (null)
index: 0x1c RID: 0x4bc acb: 0x00000011 Account: postfix Name: (null) Desc: (null)
index: 0x1d RID: 0x0bc acb: 0x00000011 Account: service Name: , Desc: (null)
index: 0x1e RID: 0x439 acb: 0x00000011 Account: list Name: Mailing List Manager Desc: (null)
index: 0x1f RID: 0x436 acb: 0x00000011 Account: irc Name: ircd Desc: (null)
index: 0x20 RID: 0x4be acb: 0x00000011 Account: ftp Name: (null) Desc: (null)
index: 0x21 RID: 0x4c4 acb: 0x00000011 Account: tomcat55 Name: (null) Desc: (null)
index: 0x22 RID: 0x3f9 acb: 0x00000011 Account: sync Name: sync Desc: (null)

```

Figure 32: enum4linux – OS information and user accounts

Output: The OS reports itself as Samba 3.0.20-Debian and the full user list comes back over the null session, including root, msfadmin, user, postgres, mysql, ftp, www-data and service.

```

Session Actions Edit View Help
Reconnecting with SMB1 for workgroup listing.

Server          Comment
Workgroup       Master
WORKGROUP       METASPLOITABLE

[*] Attempting to map shares on 192.168.56.101
//192.168.56.101/print$ Mapping: DENIED Listing: N/A Writing: N/A
//192.168.56.101/tmp Mapping: OK listing: OK Writing: N/A
//192.168.56.101/opt Mapping: DENIED Listing: N/A Writing: N/A
[*] Can't understand response:
NT_STATUS_NETWORK_ACCESS_DENIED listing \*
//192.168.56.101/IPC$ Mapping: N/A Listing: N/A Writing: N/A
//192.168.56.101/ADMIN$ Mapping: DENIED Listing: N/A Writing: N/A

===== ( Password Policy Information for 192.168.56.101 ) =====

[*] Attaching to 192.168.56.101 using a NULL share
[*] Trying protocol 139/SMB...
[*] Found domain(s):
    [*] METASPLOITABLE
    [*] BuiltIn
[*] Password Info for Domain: METASPLOITABLE
    [*] Minimum password length: 5
    [*] Password history length: None
    [*] Maximum password age: Not Set
    [*] Password Complexity Flags: 000000
        [*] Domain Refuse Password Change: 0
        [*] Domain Password Store Cleartext: 0
        [*] Domain Password Lockout Admins: 0
        [*] Domain Password No Clear Change: 0
        [*] Domain Password No Anon Change: 0
        [*] Domain Password Complexity: 0

```

Figure 33: enum4linux – share mapping and password policy

Output: Share mapping shows `tmp` is mappable and listable over the null session, while `print$`, `opt` and `ADMIN$` are denied. The password policy shows minimum length 5, complexity flags 000000 (complexity disabled), and no account lockout threshold.

```

Session Actions Edit View Help
[*] Enumerating users using SID S-1-5-21-1042354039-2475377354-766472396 and logon username '', password ''

S-1-5-21-1042354039-2475377354-766472396-500 METASPLOITABLE\Administrator (Local User)
S-1-5-21-1042354039-2475377354-766472396-501 METASPLOITABLE\nobody (Local User)
S-1-5-21-1042354039-2475377354-766472396-512 METASPLOITABLE\Domain Admins (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-513 METASPLOITABLE\Domain Users (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-514 METASPLOITABLE\Domain Guests (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1000 METASPLOITABLE\root (Local User)
S-1-5-21-1042354039-2475377354-766472396-1001 METASPLOITABLE\root (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1002 METASPLOITABLE\daemon (Local User)
S-1-5-21-1042354039-2475377354-766472396-1003 METASPLOITABLE\daemon (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1004 METASPLOITABLE\bin (Local User)
S-1-5-21-1042354039-2475377354-766472396-1005 METASPLOITABLE\bin (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1006 METASPLOITABLE\sys (Local User)
S-1-5-21-1042354039-2475377354-766472396-1007 METASPLOITABLE\sys (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1008 METASPLOITABLE\sync (Local User)
S-1-5-21-1042354039-2475377354-766472396-1009 METASPLOITABLE\adm (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1010 METASPLOITABLE\games (Local User)
S-1-5-21-1042354039-2475377354-766472396-1011 METASPLOITABLE\tty (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1012 METASPLOITABLE\man (Local User)
S-1-5-21-1042354039-2475377354-766472396-1013 METASPLOITABLE\disk (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1014 METASPLOITABLE\lp (Local User)
S-1-5-21-1042354039-2475377354-766472396-1015 METASPLOITABLE\lp (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1016 METASPLOITABLE\mail (Local User)
S-1-5-21-1042354039-2475377354-766472396-1017 METASPLOITABLE\mail (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1018 METASPLOITABLE\news (Local User)
S-1-5-21-1042354039-2475377354-766472396-1019 METASPLOITABLE\news (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1020 METASPLOITABLE\wuwp (Local User)
S-1-5-21-1042354039-2475377354-766472396-1021 METASPLOITABLE\wuwp (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1025 METASPLOITABLE\man (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1026 METASPLOITABLE\proxy (Local User)
S-1-5-21-1042354039-2475377354-766472396-1027 METASPLOITABLE\proxy (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1031 METASPLOITABLE\kmem (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1041 METASPLOITABLE\dialout (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1043 METASPLOITABLE\Fax (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1045 METASPLOITABLE\voice (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1049 METASPLOITABLE\cdrom (Domain Group)

===== ( Getting printer info for 192.168.56.101 ) =====

No printers returned.

enum4linux complete on Wed Aug 26 19:34:13 2026

bruno@kali ~$

```

Figure 34: enum4linux – user enumeration through RID cycling

Output: RID cycling walks the target's SID and returns each account, including `METASPLOITABLE\Administrator` and the same local users, which cross-checks the earlier user list.

```
(bruno@kali)~$ smbclient -i //192.168.56.101 -U msfadmin
Password for [WORKGROUP\msfadmin]:

Sharename      Type      Comment
-----
print$         Disk      Printer Drivers
tmp            Disk      oh noes!
opt            Disk
IPC$           IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
ADMIN$         IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
msfadmin       Disk      Home Directories
Reconnecting with SMB1 for workgroup listing.

Server          Comment
-----
Workgroup       Master
WORKGROUP      METASPLOITABLE

(bruno@kali)~$
```

Figure 35: smbclient – share listing on the target

Output: smbclient confirms the shares and adds the `msfadmin` home directory. The visible shares are `print$`, `tmp`, `opt`, `IPC$`, `ADMIN$` and `msfadmin`.

Default credentials for Metasploitable 2.

Username	Password
msfadmin	msfadmin
root	root

Report Questions

1. How quickly did Hydra find the default credentials?

Against the unmodified rockyou list it does not finish, because `msfadmin` does not sit near the top of that list and the full run is estimated in the hundreds to thousands of hours. When the known password is placed near the top of the list, Hydra returns `msfadmin:msfadmin` in about a minute for both SSH (09:40:12 to 09:41:09) and FTP (09:45:51 to 09:46:57), and also recovers it on the SSH default-users run. This is expected: the target has no account lockout, so once the password is within reach the number of attempts is the only limit, and a short or well-ordered list finds it almost immediately.

2. What user accounts exist on the system (from SMB enum)?

From enum4linux over the null session and confirmed by RID cycling: `root`, `msfadmin`, `user`, `postgres`, `mysql`, `ftp`, `www-data`, `service`, plus service accounts such as `bin`, `daemon`, `sshd`, `proftpd`, `tomcat55`, and the built-in Administrator.

3. What shares are available on the SMB service?

`print$`, `tmp`, `opt`, `IPC$`, `ADMIN$` and `msfadmin` (the home directory). Of these, `tmp` maps and lists over the null session, while `print$`, `opt` and `ADMIN$` are denied.

4. What does this tell you about the password policy?

It is weak. Minimum length 5, complexity disabled, and no lockout threshold. The lack of a lockout means an online guessing attack can run without ever locking the account, and the weak length and complexity rules allow short simple passwords, which is consistent with the documented defaults being reused unchanged.

Command Summary

Command	Purpose
hydra -l msfadmin -P rockyou.txt ssh://192.168.56.101	SSH brute force (one user)
hydra -L default_users.txt -P rockyou.txt ssh://192.168.56.101	SSH brute force (user list)
hydra -l msfadmin -P rockyou.txt ftp://192.168.56.101	FTP brute force
Burp Intruder on POST /dvwa/login.php	Web login brute force
enum4linux -a 192.168.56.101	Full SMB enumeration
smbclient -L //192.168.56.101 -U msfadmin	List SMB shares

Appendix A: Full Output of version-scan.txt

Complete output of `nmap -sV -sC -A 192.168.56.101`, included because the Figure 6 screenshot only shows the scan up to port 80.

```
$ nmap -sV -sC -A 192.168.56.101 -oN version-scan.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-13 08:31 EDT
Nmap scan report for 192.168.56.101
Host is up (0.0013s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_ SSLv2 supported
|_ SSL2_RC4_128_EXPORT40_WITH_MD5
|_ SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_ SSL2_RC4_128_WITH_MD5
|_ SSL2_RC2_128_CBC_WITH_MD5
|_ SSL2_DES_64_CBC_WITH_MD5
|_ SSL2_DES_192_EDE3_CBC_WITH_MD5
|_ ssl-cert: Subject: commonName=ubuntu804-base.localdomain/
|_ organizationName=OCOSA/countryName=XX
|_ Not valid before: 2010-03-17T14:07:45
|_ Not valid after: 2010-04-16T14:07:45
|_ smtp_commands: metasploitable.localdomain, PIPELINING, SIZE 10240000,
|_ VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
53/tcp    open  domain       ISC BIND 9.4.2
|_ bind.version: 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux
111/tcp   open  rpcbind      2 (RPC #100000)
|_ 100003 2,3,4 2049/tcp nfs
|_ 100005 1,2,3 44894/tcp mountd
|_ 100021 1,3,4 39081/tcp nlockmgr
|_ 100024 1 57214/tcp status
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
|_ Protocol: 10
|_ Version: 5.0.51a-3ubuntu5
|_ Status: Autocommit
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
|_ ssl-cert: Subject: commonName=ubuntu804-base.localdomain/
|_ organizationName=OCOSA/countryName=XX
5900/tcp  open  vnc           VNC (protocol 3.3)
|_ Protocol version: 3.3
|_ VNC Authentication (2)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Apache Tomcat/5.5
|_http-favicon: Apache Tomcat
MAC Address: 08:00:27:44:30:BC (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN;
OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ smb-security-mode:
|_ authentication_level: user
|_ message_signing: disabled (dangerous, but default)
|_ smb-os-discovery:
|_ OS: Unix (Samba 3.0.20-Debian)
|_ Computer name: metasploitable
|_ Domain name: localdomain
|_ FQDN: metasploitable.localdomain
|_ nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>

TRACEROUTE
HOP RTT ADDRESS
1 1.30 ms 192.168.56.101

Nmap done: 1 IP address (1 host up) scanned in 41.23 seconds
```

Appendix B: Output of vuln-scan.txt

Output of `nmap -script vuln -T4 192.168.56.101`. The repeated `http-sql-injection` URL list and the repeated `/admin/` path list have been shortened, as marked; everything else is unchanged.

```
$ nmap --script vuln -T4 192.168.56.101 -oN vuln-scan.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-13 16:54 EDT
Nmap scan report for 192.168.56.101
Host is up (0.00058s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|   vsFTPD version 2.3.4 backdoor
|   State: VULNERABLE (Exploitable)
|   IDs: BID:48539  CVE:CVE-2011-2523
|   vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|   Disclosure date: 2011-07-03
|   Exploit results:
|   Shell command: id
|   Results: uid=0(root) gid=0(root)
|   References:
|   _ https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
| ssl-poodle:
|   VULNERABLE:
|   SSL POODLE information leak
|   State: VULNERABLE
|   IDs: BID:70574  CVE:CVE-2014-3566
|   Disclosure date: 2014-10-14
|   Check results:
|   _ TLS_RSA_WITH_AES_128_CBC_SHA
|   smtp-vuln-cve2010-4344:
|   The SMTP server is not Exim: NOT VULNERABLE
| ssl-dh-params:
|   VULNERABLE:
|   Anonymous Diffie-Hellman Key Exchange MitM Vulnerability
|   State: VULNERABLE
|   Check results:
|   ANONYMOUS DH GROUP 1
|   Cipher Suite: TLS_DH_anon_WITH_AES_256_CBC_SHA
|   Modulus Source: postfix builtin
|   Modulus Length: 1024
|
|   TLS Protocol DHE_EXPORT Ciphers Downgrade MitM (Logjam)
|   State: VULNERABLE
|   IDs: BID:74733  CVE:CVE-2015-4000
|   Disclosure date: 2015-5-19
|   Check results:
|   EXPORT-GRADE DH GROUP 1
|   Cipher Suite: TLS_DHE_RSA_EXPORT_WITH_DES40_CBC_SHA
|   Modulus Length: 512
|
|   Diffie-Hellman Key Exchange Insufficient Group Strength
|   State: VULNERABLE
|   Check results:
|   WEAK DH GROUP 1
|   Cipher Suite: TLS_DHE_RSA_WITH_3DES_EDE_CBC_SHA
|   Modulus Length: 1024
|_
53/tcp    open  domain
80/tcp    open  http
|_http-trace: TRACE is enabled
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
| http-csrf:
|   Found the following possible CSRF vulnerabilities:
|   Path: http://192.168.56.101:80/dvwa/      Form action: login.php
|   Path: http://192.168.56.101:80/dvwa/login.php Form action: login.php
|   Path: .../twiki/TWikiDocumentation.html (6 forms)
|   Path: .../mutillidae/index.php?page=... (3 forms)
|_ http-slowloris-check:
|   VULNERABLE:
|   Slowloris DOS attack
|   State: LIKELY VULNERABLE
|   IDs: CVE:CVE-2007-6750
|   Disclosure date: 2009-09-17
|_ http-sql-injection:
|   Possible sql_i for queries:
|   http://192.168.56.101:80/dav/?C=M;3B0%3DA%27%20OR%20sqlspider
|   http://192.168.56.101:80/mutillidae/index.php?page=login.php%27%20OR%20sqlspider
|   http://192.168.56.101:80/mutillidae/index.php?page=user-info.php%27%20OR%20sqlspider
|   [ ... approximately 180 further /dav/, /mutillidae/ and /twiki/ URLs ... ]
|   Possible sql_i for forms:
|   Form at path: /mutillidae/index.php, action: index.php
|_   Fields that might be vulnerable: choice, initials
|_ http-enum:
|   /tikiwiki/: Tikiwiki
|   /test/: Test page
|   /phpinfo.php: Possible information file
|   /phpMyAdmin/: phpMyAdmin
|   /doc/: Potentially interesting directory w/ listing on 'apache/2.2.8 (ubuntu) dav/2'
```

```

| /icons/: Potentially interesting folder w/ directory listing
|_ /index/: Potentially interesting folder
111/tcp open rpcbind
139/tcp open netbios-ssn
445/tcp open microsoft-ds
512/tcp open exec
513/tcp open login
514/tcp open shell
1099/tcp open rmiregistry
| rmi-vuln-classloader:
|   VULNERABLE:
|     RMI registry default configuration remote code execution vulnerability
|     State: VULNERABLE
|     Default configuration of RMI registry allows loading classes from
|_     remote URLs which can lead to remote code execution.
1524/tcp open ingreslock
2049/tcp open nfs
2121/tcp open cproxy-ftp
3306/tcp open mysql
|_ssl-ccs-injection: No reply from server (TIMEOUT)
5432/tcp open postgresql
| ssl-dh-params:
|   VULNERABLE:
|     Diffie-Hellman Key Exchange Insufficient Group Strength
|     State: VULNERABLE
|     WEAK DH GROUP 1, Modulus Length: 1024
| ssl-poodle:
|   VULNERABLE:
|     SSL POODLE information leak
|_   State: VULNERABLE   IDs: BID:70574   CVE:CVE-2014-3566
| ssl-ccs-injection:
|   VULNERABLE:
|     SSL/TLS MITM vulnerability (CCS Injection)
|     State: VULNERABLE
|     Risk factor: High
|_   CVE-2014-0224
5900/tcp open vnc
6000/tcp open X11
6667/tcp open irc
|_irc-unrealircd-backdoor: Looks like trojaned version of unrealircd.
8009/tcp open ajp13
8180/tcp open unknown
| http-cookie-flags:
|   /admin/, /admin/index.jsp, /admin/login.jsp and 21 further paths:
|   JSESSIONID:
|_   httponly flag not set
| http-slowloris-check:
|   VULNERABLE:
|     Slowloris DOS attack
|     State: LIKELY VULNERABLE
|_   IDs:   CVE:CVE-2007-6750
| http-enum:
|   /admin/ and 20 further admin paths: Possible admin folder
|   /manager/html: Apache Tomcat (401 Unauthorized)
|   /manager/html/upload: Apache Tomcat (401 Unauthorized)
|_   /webdav/: Potentially interesting folder
MAC Address: 08:00:27:44:30:BC (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Host script results:
|_smb-vuln-ms10-054: false
|_smb-vuln-ms10-061: false

Nmap done: 1 IP address (1 host up) scanned in 328.50 seconds

```